

WebTrust Testing Approach Overview

JUNE 4, 2026



cpa

CHARTERED
PROFESSIONAL
ACCOUNTANTS
CANADA

COMPTABLES
PROFESSIONNELS
AGRÉÉS
CANADA

Audit Considerations

- What Are We Providing Assurance Over?
- Understanding the Environment Behind the Output
- Risk Assessment: Where Trust Breaks Down
- Audit Execution: Validating the Integrity of the System
- Visible Output vs Invisible Trust
- Contact Information
- Appendix

What Are We Providing Assurance Over?

Beyond certificates → trust in the system that produces them

The visible output (e.g., certificates) is only the surface. Anyone can inspect technical attributes of the certificates.

WebTrust assurance is fundamentally about what cannot be directly observed:

- Governance over certificate lifecycle processes
- Integrity and security of systems and PKI infrastructure
- Reliability of people and operational execution

Auditor judgement bridges the gap:

- From technical correctness of outputs
- To credibility of the processes that produced them

Objective:

- Provide confidence that outputs remain valid, consistently and at scale

Understanding the Environment Behind the Output

Trust depends on integrity of the ecosystem, not just the artifact

Auditors must develop a deep understanding of:

- End-to-end subscriber and certificate lifecycle processes
- Interdependencies across systems, controls, and people
- Design and purpose of controls relative to risks

Critical dimensions of the environment:

- Automation vs. manual intervention
- Change management and access controls within PKI systems
- Competence and authority of personnel

Key insight:

A technically valid certificate is meaningless if:

- The process generating it is not controlled
- The environment cannot be trusted

Risk Assessment: Where Trust Can Break Down

Identifying where invisible failures could compromise visible outputs

Risk assessment focuses on how and where controls could fail, not just whether outputs look correct:

- Complexity of processes and level of judgement involved
- System changes, upgrades, or migrations affecting integrity
- History of deviations, exceptions, or control breakdowns

Examples of “invisible risk”:

- Unauthorized changes to certificate issuance logic
- Weak access controls over CA or signing systems
- Inconsistent execution of validation procedures
- Over-reliance on individuals without oversight

Auditor judgement translates these risks into:

- What artifacts must be tested
- What levels of evidence are required to support the risk

Audit Execution: Validating the Integrity of the System

Providing assurance that outputs are trustworthy, not just correct

Testing focuses on whether controls:

- Operate consistently, by authorized individuals
- Address risks across process, system, and human layers

Key audit activities:

- Testing design and operating effectiveness of controls
- Validating completeness and accuracy of populations and data (IPE)
- Assessing both manual and automated control environments

The real assurance provided:

- Not just that certificates are technically valid
- But that they are:
 - Generated through controlled, governed processes
 - Backed by reliable systems
 - Executed by competent and accountable people

Bottom line:

- WebTrust provides trust in the unseen system, which is what ultimately makes the visible output trustworthy

Visible Output vs Invisible Trust

Visible Output

Certificates/Artefacts

Technically valid • Publicly observable • Point-in-time correctness

Looks correct but is it trustworthy?

Invisible trust layers: what WebTrust actually assures:

GOVERNANCE

- Policies & standards
- Oversight & accountability
- Risk management

SYSTEMS

- PKI architecture & configuration
- Access & change controls
- Logging & monitoring

PROCESSES

- Certificate lifecycle controls
- Validation & authorization
- Consistent execution at scale

PEOPLE

- Competence & training
- Segregation of duties
- Accountability

Contact Information

Lilia Dubko	CPA Canada	ldubko@cpacanada.ca
Tim Crawford	WebTrust Task Force Co-Chair	tcrawford@bdo.com
Christopher Czajczyc	WebTrust Task Force Member	cczajczyc@deloitte.ca
Eric Lin	WebTrust Task Force Member	eric.lin@ey.com



APPENDIX

- Automated Controls
- Manual and Mixed Controls
- Obtaining and Assessing a Population
- Population Example - Firewall Changes
- Population Example - EV TLS Certificate Issuance

AUTOMATED CONTROLS

Example Controls	Example Test Approaches
ACME Domain Control Validation is performed by the system.	• Inspect attributes of validation process to ensure it aligns with the required method. • Perform test validation for both pass and fail example of DCV method.
Certificates are linted based on a designated profile after issuance.	• Inspect the certificate profile in linting software. • Provide the linter test certificates and observe the output.

MANUAL AND MIXED CONTROLS

Example Controls	Example Test Approaches
The Policy Management Authority (PMA) reviews and approves each new version of the CP/CPS. (fully manual)	• Obtain a PMA charter to understand the approved members and how many are required to approve a new policy version. • Make a selection of policy versions during the period and obtain evidence approval was documented.
HR initiates a termination process in the system and access is removed from all single sign on systems automatically and other systems are removed manually. (mixed control)	• Observe configurations to determine systems configured to remove access in an automated fashion. • Make a selection of terminated employees to test employment date was entered properly and access was removed timely.

OBTAINING AND ASSESSING A POPULATION

Population Elements	Considerations
Definition of the population	• How does a list of transactions need to be separated or divided into subsets?
Population Source	• What is the best source for the population? • Are there risks with using certain sources compared to others?
Population completeness	• How do we ensure all transactions are included in a report? • Has there been any modifications to the report? • What is the period the initial population is generated?

POPULATION EXAMPLE – FIREWALL CHANGES

Population Elements	Considerations
Definition of the population	• Filter a list of firewall changes to those changes applicable to CA systems.
Population Source	• Are change management tickets sufficient? • Is there a risk a change happened without a ticket? • Can the appliance provide logs of changes that can be matched to tickets?
Population completeness	• Auditor can observe the report of changes being generated from appliance to ensure there are no edits. • Understand how the report is filtered to the appropriate scope.

POPULATION EXAMPLE – EV TLS CERTIFICATE ISSUANCES

Population Elements	Considerations
Definition of the population	• Are we testing the certificate content or the validation? • List of issuance will not weigh evenly across unique validation transactions.
Population Source	• Can RA and CA logs be used to separate types of certificates? • Consider CT logs as a source.
Population completeness	• Auditor can observe the report of changes being generated from appliance to ensure there are no edits. • Understand how the report is filtered to the appropriate scope. • Can verify against CT logs.